WAS Web Application Report

QUALYS® EXPRESS

Web Application Report-20170314

14 Mar 2017

Each targeted web application is listed with the total number of detected vulnerabilities and sensitive content.

Muneeb Imtiaz
sbank-mm

JS Bank
1st Floor, Shaheen Complex I. I. Chundrigar Road
Karachi, None 75500
Pakistan

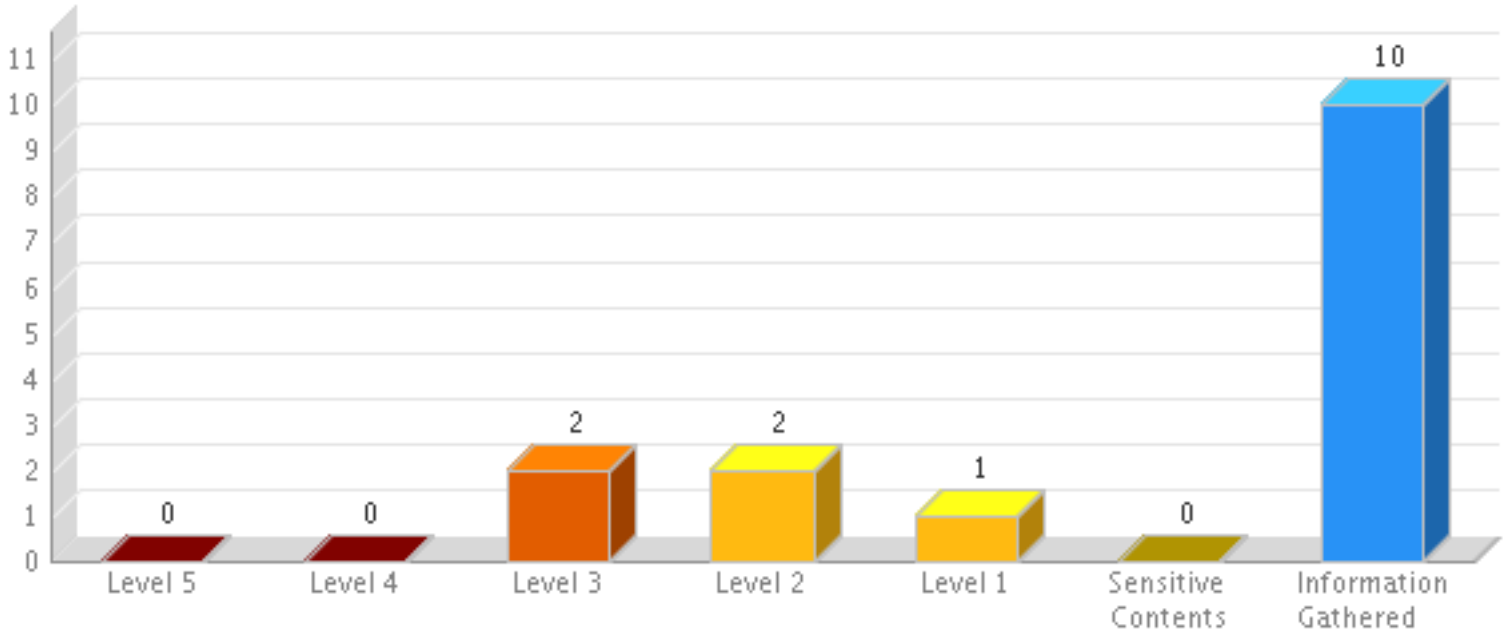
Target and Filters

Web Applications (1)	https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
Status	New, Active, Re-Opened

Summary

Security Risk	Web Applications	Vulnerabilities	Sensitive Contents	Information Gathered
MED	1	5	0	10

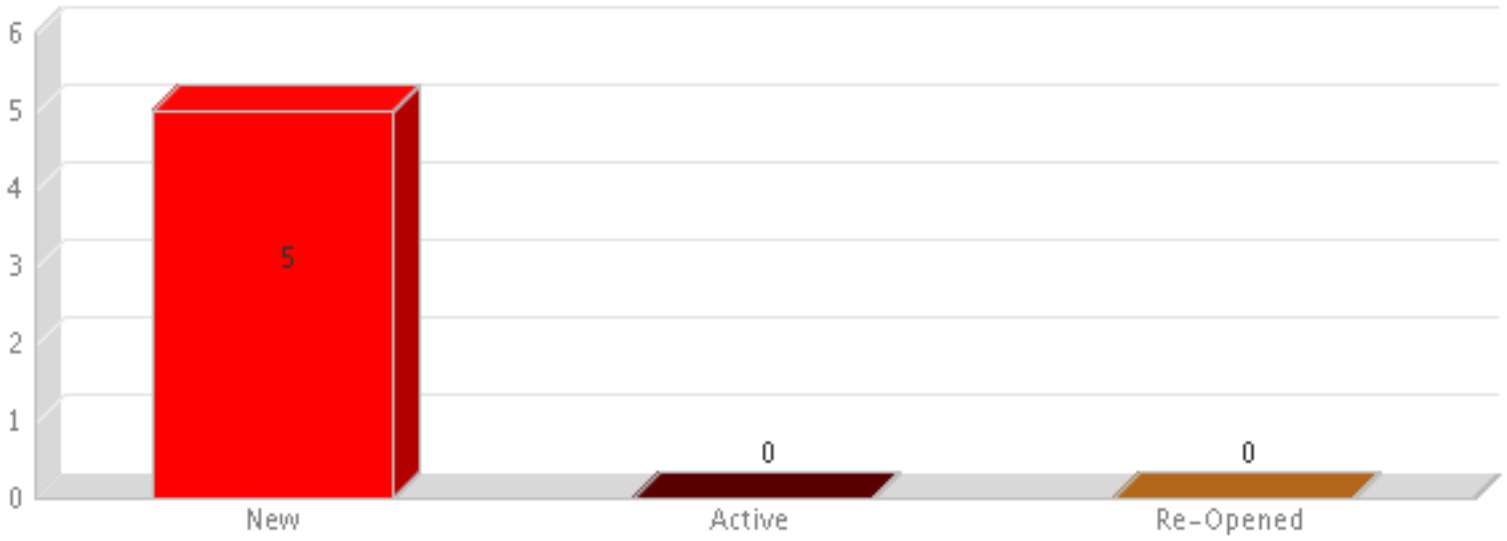
Findings by Severity



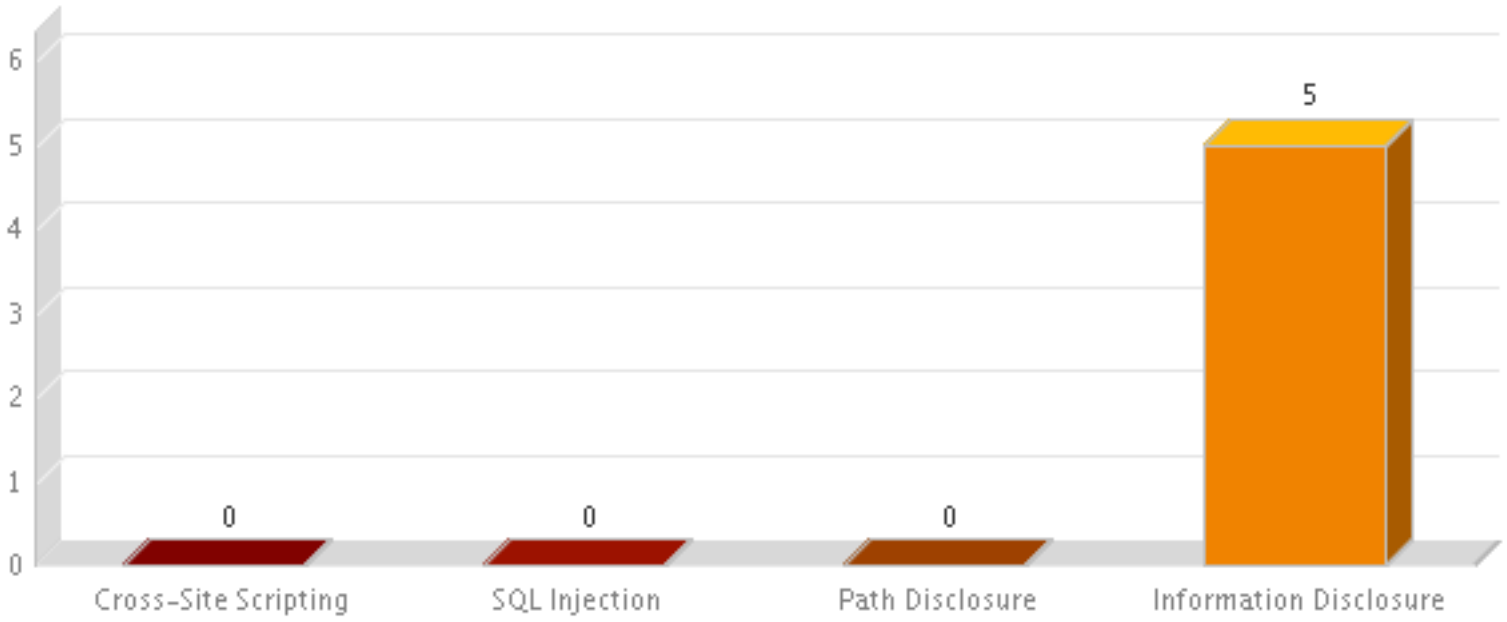
CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

WAS Web Application Report

Vulnerabilities by Status



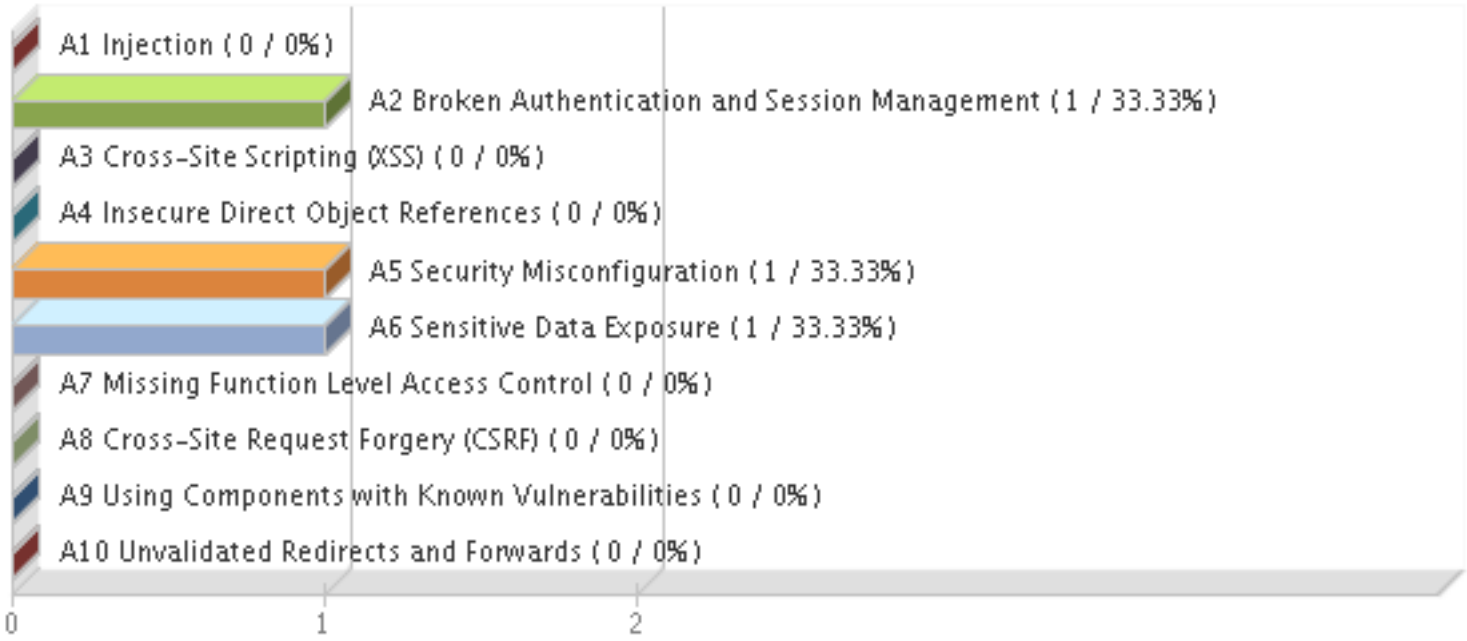
Vulnerabilities by Group



CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

WAS Web Application Report

OWASP Top 10 2013 Vulnerabilities



Web Application	Level 5	Level 4	Level 3	Level 2	Level 1	Sensitive Contents	Information Gathered
https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx	0	0	2	2	1	0	10

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

WAS Web Application Report

Results(15)

Vulnerability (5)

Information Disclosure (5)

150124 Clickjacking - Framable Page (1)

150124 Clickjacking - Framable Page *https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx* **New**

URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	3623904	**Severity**	Confirmed Vulnerability - Level 3
Group	Information Disclosure	**First Time Detected**	14 Mar 2017 11:59 GMT+0500
CWE	-	**Last Time Detected**	14 Mar 2017 11:59 GMT+0500
OWASP	-	**Last Time Tested**	14 Mar 2017 11:59 GMT+0500
WASC	-	**Times Detected**	1
CVSS Base	2.1	**CVSS Temporal**	1.9

Details

Threat

The page can be easily framed. Anti-framing measures are not used.

Impact

Clickjacking and Cross-Site Request Forgery (CSRF) can be performed by framing the target site. An attack can trick the user into clicking on the link by framing the original page and showing a layer on top of it with dummy buttons.

Solution

Two of the most popular prevention are: X-Frame-Options: This header works with modern browsers and can be used to prevent framing of the page. Note that is must be an HTTP header, the setting is ignored if it is created as an "http-equiv" meta element within the page. Framekiller: JavaScript code that prevents the malicious user from framing the page.

Detection Information

Parameter	No param has been required for detecting the information.
Authentication	In order to detect this vulnerability, no authentication has been required.

Payloads

#1 Request

Payload	N/A
Request	GET https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Click this link to try to reproduce the vulnerability using above payload.Note that clicking this link may not lead to visible results, either because the vulnerability requires context to be previously set (authentication, cookies...) or because the exploitation of the vulnerability does not lead to any visible proof.

#1 Response

The URI was framed.

150161 Session Cookie Does Not Contain the "Secure" Attribute (1)

150161 Session Cookie Does Not Contain the "Secure" Attribute *https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx* **New**

URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	3623903	**Severity**	Confirmed Vulnerability - Level 3

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

Group	Information Disclosure	First Time Detected	14 Mar 2017 11:59 GMT+0500
CWE	-	Last Time Detected	14 Mar 2017 11:59 GMT+0500
OWASP	-	Last Time Tested	14 Mar 2017 11:59 GMT+0500
WASC	-	Times Detected	1
CVSS Base	-	CVSS Temporal	-

Details

Threat
The session cookie does not contain the "secure" attribute

Impact
Session Cookies with "secure" attribute are only permitted to be sent via HTTPS. Session cookies sent via HTTP expose users to sniffing attacks that could lead to user impersonation or account compromise

Solution
Apply the "secure" attribute to session cookies to ensure that they will be sent via HTTPS only.

Detection Information

Parameter	No param has been required for detecting the information.
Authentication	In order to detect this vulnerability, no authentication has been required.

Payloads

#1 Request

Payload	N/A
Request	GET https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Click this link to try to reproduce the vulnerability using above payload.Note that clicking this link may not lead to visible results, either because the vulnerability requires context to be previously set (authentication, cookies...) or because the exploitation of the vulnerability does not lead to any visible proof.

#1 Response

```
ASP.NET_SessionId=heqmprq1rsonpaqd0btphsvp; path=/; domain=10.111.200.118; httponly
```

150112 Sensitive form field has not disabled autocomplete (1)

150112 Sensitive form field has not disabled autocomplete — *https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx* **New**

URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	3623901	Severity	Confirmed Vulnerability - Level 2
Group	Information Disclosure	First Time Detected	14 Mar 2017 11:59 GMT+0500
CWE	-	Last Time Detected	14 Mar 2017 11:59 GMT+0500
OWASP	A5 Security Misconfiguration	Last Time Tested	14 Mar 2017 11:59 GMT+0500
WASC	-	Times Detected	1
CVSS Base	-	CVSS Temporal	-

Details

Threat
An HTML form that collects sensitive information (such as a password field) does not prevent the browser from prompting the user to save the populated values for later reuse. Stored credentials should not be available to anyone but their owner.

Impact

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

If the browser is used in a shared computing environment where more than one person may use the browser, then "autocomplete" values may be submitted by an unauthorized user. For example, if a browser saves the login name and password for a form, then anyone with access to the browser may submit the form and authenticate to the site without having to know the victim's password.

Solution

Add the following attribute to the form or input element: autocomplete="off" This attribute prevents the browser from prompting the user to save the populated form values for later reuse.

Detection Information

Parameter	No param has been required for detecting the information.
Authentication	In order to detect this vulnerability, no authentication has been required.

Payloads

#1 Request

Payload	N/A
Request	POST https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Click this link to try to reproduce the vulnerability using above payload.Note that clicking this link may not lead to visible results, either because the vulnerability requires context to be previously set (authentication, cookies...) or because the exploitation of the vulnerability does not lead to any visible proof.

#1 Response

The following password field(s) in the form do not set autocomplete="off":
(Field name: txtSUS_PASSWROD, Field id: txtSUS_PASSWROD)
Parent URL of form is: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

150122 Cookie Does Not Contain The "secure" Attribute (1)

150122 Cookie Does Not Contain The "secure" Attribute — *https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx* **New**

URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	3623902	**Severity**	Confirmed Vulnerability - Level 2
Group	Information Disclosure	**First Time Detected**	14 Mar 2017 11:59 GMT+0500
CWE	-	**Last Time Detected**	14 Mar 2017 11:59 GMT+0500
OWASP	A2 Broken Authentication and Session Management A6 Sensitive Data Exposure	**Last Time Tested**	14 Mar 2017 11:59 GMT+0500
WASC	-	**Times Detected**	1
CVSS Base	6.4	**CVSS Temporal**	5.8

Details

Threat

The cookie does not contain the "secure" attribute.

Impact

Cookies with the "secure" attribute are only permitted to be sent via HTTPS. Cookies sent via HTTP expose an unsuspecting user to sniffing attacks that could lead to user impersonation or compromise of the application account.

Solution

If the associated risk of a compromised account is high, apply the "secure" attribute to cookies and force all sensitive requests to be sent via HTTPS.

Detection Information

Parameter	

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

	No param has been required for detecting the information.
Authentication	In order to detect this vulnerability, no authentication has been required.

Payloads

#1 Request

Payload	N/A
Request	GET https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Click this link to try to reproduce the vulnerability using above payload.Note that clicking this link may not lead to visible results, either because the vulnerability requires context to be previously set (authentication, cookies...) or because the exploitation of the vulnerability does not lead to any visible proof.

#1 Response

ASP.NET_SessionId=heqmprq1rsonpaqd0btphsvp; path=/; domain=10.111.200.118; httponly

150081 Clickjacking - X-Frame-Options header is not set (1)

150081 Clickjacking - X-Frame-Options header is not set *https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx* **New**

URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	3623905	**Severity**	Potential Vulnerability - Level 1
Group	Information Disclosure	**First Time Detected**	14 Mar 2017 11:59 GMT+0500
CWE	-	**Last Time Detected**	14 Mar 2017 11:59 GMT+0500
OWASP	-	**Last Time Tested**	14 Mar 2017 11:59 GMT+0500
WASC	-	**Times Detected**	1
CVSS Base	2.1	**CVSS Temporal**	1.7

Details

Threat

X-Frame-Options header is not set, and that may lead to a possible framing of the page. An attacker can trick the user into clicking on the link by framing the original page and showing a layer on top of it with dummy buttons.

Impact

Attacks like Clickjacking and Cross-Site Request Forgery (CSRF) could be performed.

Solution

Set the X-Frame-Options: This header works with modern browsers and can be used to prevent framing of the page. Note that it must be an HTTP header, the setting is ignored if it is created as an "http-equiv" meta element within the page.

Detection Information

Parameter	No param has been required for detecting the information.
Authentication	In order to detect this vulnerability, no authentication has been required.

Payloads

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

#1 Request

Payload	N/A
Request	GET https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Click this link to try to reproduce the vulnerability using above payload.Note that clicking this link may not lead to visible results, either because the vulnerability requires context to be previously set (authentication, cookies...) or because the exploitation of the vulnerability does not lead to any visible proof.

#1 Response

The response for this request either did not have an "X-FRAME-OPTIONS" header present or was not set to DENY or SAMEORIGIN

Information Gathered (10)

Information Gathered (10)

45017 Operating System Detected (1)

45017 Operating System Detected — *https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx*

Finding #	1119830	**Severity**	Information Gathered - Level 2
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat

Several different techniques can be used to identify the operating system (OS) running on a host. A short description of these techniques is provided below. The specific technique used to identify the OS on this host is included in the RESULTS section of your report.

1) **TCP/IP Fingerprint**: The operating system of a host can be identified from a remote system using TCP/IP fingerprinting. All underlying operating system TCP/IP stacks have subtle differences that can be seen in their responses to specially-crafted TCP packets. According to the results of this "fingerprinting" technique, the OS version is among those listed below.

Note that if one or more of these subtle differences are modified by a firewall or a packet filtering device between the scanner and the host, the fingerprinting technique may fail. Consequently, the version of the OS may not be detected correctly. If the host is behind a proxy-type firewall, the version of the operating system detected may be that of the firewall instead of the host being scanned.

2) **NetBIOS**: Short for Network Basic Input Output System, an application programming interface (API) that augments the DOS BIOS by adding special functions for local-area networks (LANs). Almost all LANs for PCs are based on the NetBIOS. Some LAN manufacturers have even extended it, adding additional network capabilities. NetBIOS relies on a message format called Server Message Block (SMB).

3) **PHP Info**: PHP is a hypertext pre-processor, an open-source, server-side, HTML-embedded scripting language used to create dynamic Web pages. Under some configurations it is possible to call PHP functions like phpinfo() and obtain operating system information.

4) **SNMP**: The Simple Network Monitoring Protocol is used to monitor hosts, routers, and the networks to which they attach. The SNMP service maintains Management Information Base (MIB), a set of variables (database) that can be fetched by Managers. These include "MIB_II.system.sysDescr" for the operating system.

Impact

Not applicable.

Solution

Not applicable.

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

Results

Operating System	Technique	ID
Windows Vista / Windows 2008 / Windows 7 / Windows 2012 / Windows 8 / Windows 10	TCP/IP Fingerprint	U3414:443

6 DNS Host Name (1)

6 DNS Host Name

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1119819	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat

The fully qualified domain name of this host, if it was obtained from a DNS server, is displayed in the RESULT section.

Impact

Results

IP address	Host name
10.111.200.118	homeremituat.jsbl.com

45038 Host Scan Time (1)

45038 Host Scan Time

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1119825	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat

The Host Scan Time is the period of time it takes the scanning engine to perform the vulnerability assessment of a single target host. The Host Scan Time for this host is reported in the Result section below.

The Host Scan Time does not have a direct correlation to the Duration time as displayed in the Report Summary section of a scan results report. The Duration is the period of time it takes the service to perform a scan task. The Duration includes the time it takes the service to scan all hosts, which may involve parallel scanning. It also includes the time it takes for a scanner appliance to pick up the scan task and transfer the results back to the service's Secure Operating Center. Further, when a scan task is distributed across multiple scanners, the Duration includes the time it takes to perform parallel host scanning on all scanners.

For host running the Qualys Windows agent this QID reports the time taken by the agent to collect the host metadata used for the most recent assessment scan.

Impact

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

N/A

Solution
N/A

Results

Scan duration: 432 seconds

Start time: Tue, Mar 14 2017, 07:02:00 GMT

End time: Tue, Mar 14 2017, 07:09:12 GMT

150009 Links Crawled (1)

150009 Links Crawled

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1119831	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat
The list of unique links crawled and HTML forms submitted by the Web application scanner appear in the Results section. This list may contain fewer links than the maximum threshold defined at scan launch. The maximum links to crawl includes links in this list and requests for the same link made as an anonymous and authenticated user.

Impact
N/A

Solution
N/A

Results

Duration of crawl phase (seconds): 195.00
Number of links: 1
(This number excludes form requests and links re-requested during authentication.)

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

150021 Scan Diagnostics (1)

150021 Scan Diagnostics

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1119820	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

WAS Web Application Report

This check provides various details of the scan's performance and behavior. In some cases, this check can be used to identify problems that the scanner encountered when crawling the target Web application.

Impact

The scan diagnostics data provides technical details about the crawler's performance and behavior. This information does not necessarily imply problems with the Web application.

Solution

No action is required.

Results

Loaded 0 blacklist entries.
Loaded 0 whitelist entries.
HTML form authentication unavailable, no WEBAPP entry found
Collected 4 links overall.
Path manipulation: Estimated requests (payloads x links): files with extension:(0 x 1) + files:(0 x 1) + directories:(9 x 3) + paths:(0 x 4) = total (27)
Batch #0 WS Directory Path manipulation: estimated time < 1 minute (9 tests, 4 inputs)
WS Directory Path manipulation: 9 vulnsigs tests, completed 27 requests, 0 seconds. Completed 27 requests of 27 estimated requests (100%). All tests completed.
Batch #0 WS enumeration: estimated time < 1 minute (10 tests, 4 inputs)
WS enumeration: 10 vulnsigs tests, completed 30 requests, 0 seconds. Completed 30 requests of 40 estimated requests (75%). All tests completed.
Batch #1 URI parameter manipulation (no auth): estimated time < 1 minute (48 tests, 0 inputs)
Batch #1 URI parameter manipulation (no auth): 48 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #1 Form parameter manipulation (no auth): estimated time < 1 minute (48 tests, 7 inputs)
Batch #1 Form parameter manipulation (no auth): 48 vulnsigs tests, completed 337 requests, 2 seconds. Completed 337 requests of 336 estimated requests (100.298%). All tests completed.
Batch #1 URI blind SQL manipulation (no auth): estimated time < 1 minute (9 tests, 0 inputs)
Batch #1 URI blind SQL manipulation (no auth): 9 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #1 Form blind SQL manipulation (no auth): estimated time < 1 minute (9 tests, 7 inputs)
Batch #1 Form blind SQL manipulation (no auth): 9 vulnsigs tests, completed 72 requests, 0 seconds. Completed 72 requests of 189 estimated requests (38.0952%). All tests completed.
Batch #1 Form field time-based tests (no auth): estimated time < 1 minute (11 tests, 7 inputs)
Batch #1 Form field time-based tests (no auth): 11 vulnsigs tests, completed 44 requests, 0 seconds. Completed 44 requests of 77 estimated requests (57.1429%). All tests completed.
Batch #4 DOM XSS exploitation: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 DOM XSS exploitation: 1 vulnsigs tests, completed 0 requests, 1 seconds. No tests to execute.
Batch #4 HTTP call manipulation: estimated time < 1 minute (33 tests, 0 inputs)
Batch #4 HTTP call manipulation: 33 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #4 Open Redirect analysis: estimated time < 1 minute (1 tests, 0 inputs)
Batch #4 Open Redirect analysis: 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
CSRF tests will not be launched because the scan is not successfully authenticated.
Batch #4 File Inclusion analysis: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 File Inclusion analysis: 1 vulnsigs tests, completed 0 requests, 0 seconds. Completed 0 requests of 1 estimated requests (0%). All tests completed.
Batch #4 Cookie manipulation: estimated time < 1 minute (37 tests, 1 inputs)
Batch #4 Cookie manipulation: 37 vulnsigs tests, completed 13 requests, 0 seconds. Completed 13 requests of 13 estimated requests (100%). XSS optimization removed 24 links. All tests completed.
Batch #4 Header manipulation: estimated time < 1 minute (37 tests, 1 inputs)
Batch #4 Header manipulation: 37 vulnsigs tests, completed 22 requests, 1 seconds. Completed 22 requests of 24 estimated requests (91.6667%). XSS optimization removed 24 links. All tests completed.
Batch #4 shell shock detector: estimated time < 1 minute (1 tests, 1 inputs)
Batch #4 shell shock detector: 1 vulnsigs tests, completed 1 requests, 0 seconds. Completed 1 requests of 1 estimated requests (100%). All tests completed.
Batch #4 shell shock detector(form): estimated time < 1 minute (1 tests, 0 inputs)
Batch #4 shell shock detector(form): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
HTTProxy no tests enabled.
Batch #4 Login Brute Force manipulation: estimated time < 1 minute (188 tests, 1 inputs)
Batch #4 Login Brute Force manipulation: 188 vulnsigs tests, completed 188 requests, 216 seconds. Completed 188 requests of 188 estimated requests (100%). All tests completed.
Batch #4 insecurely served cred forms detector (no auth): estimated time < 1 minute (1 tests, 2 inputs)
Batch #4 insecurely served cred forms detector (no auth): 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Batch #5 HTTP Time Bandit: estimated time < 1 minute (1 tests, 10 inputs)
Batch #5 HTTP Time Bandit: 1 vulnsigs tests, completed 0 requests, 0 seconds. No tests to execute.
Path manipulation: Estimated requests (payloads x links): files with extension:(4 x 1) + files:(15 x 1) + directories:(88 x 3) + paths:(16 x 4) = total (347)
Batch #5 Path manipulation: estimated time < 1 minute (123 tests, 4 inputs)
Batch #5 Path manipulation: 123 vulnsigs tests, completed 343 requests, 1 seconds. Completed 343 requests of 347 estimated requests (98.8473%). All tests completed.
Total requests made: 1114
Average server response time: 0.10 seconds
Most recent links:
First column indicates HTTP response code,
Special cases:
-TO: The request timed out
-CE: The request did not complete due to connection error):
404 https://10.111.200.118/JSBHMREMITSSL/phpinfo.php
404 https://10.111.200.118/JSBHMREMITSSL/presentation/phpinfo.php
404 https://10.111.200.118/info.php
404 https://10.111.200.118/JSBHMREMITSSL/info.php
404 https://10.111.200.118/JSBHMREMITSSL/presentation/info.php
404 https://10.111.200.118/.git/config
404 https://10.111.200.118/JSBHMREMITSSL/.git/config
404 https://10.111.200.118/JSBHMREMITSSL/presentation/.git/config
200 https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx?method:%23_memberAccess%3d%40ognl.OgnlContext%20%40DEFAULT_MEMBER_ACCESS%2c%23a%3d%40java.lang.Runtime%40getRuntime%28%29.exec%28%23parameters.command%20%5B0%5D%29.getInputStream%28%29%2c%23b%3dnew%20java.io.InputStreamReader%28%23a%29%2c%23c%3dnew%20%20java.io.BufferedReader%28%23b%29%2c%23d%3dnew%20char%5B51020%5D%2c%23c.read%28%23d%29%2c%23kxlzx%3d%20%40org.apache.struts2.ServletActionContext%40getResponse%28%29.getWriter%28%29%2c%23kxlzx.p...(truncated)
200 https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx?QGFakeParam%3D%25%7B%28%23_memberAccess%5B%27allowStaticMethodAccess%27%5D%3Dtrue%29%28%23context%5B%27xwork.MethodAccessor.denyMethodExecution%27%5D%3Dfalse%29%28%23writer%3D@org.apache.struts2.ServletActionContext@getResponse%28%29.getWriter%28%29%2C

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

%23writer.println%28%27QG%27%20%2b%20%27Test%27%20%2b%20%27Request%27%20%2b%2034%20%2a%2089%20%2a%2088%29%2C%23writer.close%28%29%29%7D

150028 Cookies Collected (1)

150028 Cookies Collected

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1119824	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat
The cookies listed in the Results section were received from the web application during the crawl phase.

Impact
Cookies may contain sensitive information about the user. Cookies sent via HTTP may be sniffed.

Solution
Review cookie values to ensure that sensitive information such as passwords are not present within them.

Results

Total cookies: 2
ASP.NET_SessionId=heqmprq1rsonpaqd0btphsvp; HttpOnly; path=/ First set at URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
.SoneriLogIn=; HttpOnly; expires=Mon, 11-Oct-1999 19:00:00 GMT; path=/ First set at URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

150099 Cookies Issued Without User Consent (1)

150099 Cookies Issued Without User Consent

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1119827	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat
The cookies listed in the Results section were issued from the web application during the crawl without accepting any opt-in dialogs.

Impact
Cookies may be set without user explicitly agreeing to accept them.

Solution
Review the application to ensure that all cookies listed are supposed to be issued without user opt-in. If the EU Cookie law is applicable for this web application, ensure these cookies require user opt-in or have been classified as exempt by your organization.

Results

Total cookies: 2
ASP.NET_SessionId=gfalf2ja1lentg55isjntuzq; HttpOnly; path=/ First set at URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
.SoneriLogIn=; HttpOnly; expires=Mon, 11-Oct-1999 19:00:00 GMT; path=/ First set at URL: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

WAS Web Application Report

150115 Authentication Form found (1)

150115 Authentication Form found

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1133135	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat

Authentication Form was found during the web application crawling.

Impact

N/A

Solution

N/A

Results

Authentication form found at: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
Action uri: https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
Fields: __EVENTTARGET, __EVENTARGUMENT, __VIEWSTATE_KEY, __EVENTVALIDATION, __VIEWSTATE, txtSUS_USERCODE, txtSUS_PASSWROD

150135 Strict Transport Security Missing Header Analysis (1)

150135 Strict Transport Security Missing Header Analysis

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1133136	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat

HTTP Strict Transport Security (HSTS) header missing and max-age set below 120 days.

Impact

If HSTS header is not set by Web applications using TLS, users are potentially vulnerable to active Man-in-the-middle(MITM), SSL Striping and passive eavesdropper attacks.

Solution

1. The strongest protection is to ensure that all requested resources use only TLS with well-formed HSTS header. 2. It's advisable to assign max-age directive's value to be greater than 120 days.

Results

Strict Transport Security header missing for
https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
Similar misconfiguration observed for 1 http(s) links.

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

150152 Forms Crawled (1)

150152 Forms Crawled

https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Finding #	1119822	**Severity**	Information Gathered - Level 1
Group	Information Gathered		
CWE	-	**Detection Date**	14 Mar 2017 11:59 GMT+0500
OWASP	-		
WASC	-		

Details

Threat

The list and details of unique forms submitted by the Web application scanner appear in the Results section. This list does not contain authentication forms (i.e. login forms) which are reported separately in QID 150115.

Impact

N/A

Solution

N/A

Results

Total internal forms seen (this count includes duplicate forms): 0

Crawled forms (Total: 0)
NOTE: This does not include authentication forms. Authentication forms are reported separately in QID 150115

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

WAS Web Application Report

Appendix

Web Application Details
https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx

Name	https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
URL	https://10.111.200.118/JSBHMREMITSSL/presentation/login.aspx
Owner	Akber Sultan (sbank-as)
Scope	Limit to URL hostname
Operating System	Windows Vista / Windows 2008 / Windows 7 / Windows 2012 / Windows 8 / Windows 10

Severity Levels
Confirmed Vulnerabilities

Vulnerabilities (QIDs) are design flaws, programming errors, or mis-configurations that make your web application and web application platform susceptible to malicious attacks. Depending on the level of the security risk, the successful exploitation of a vulnerability can vary from the disclosure of information to a complete compromise of the web application and/or the web application platform. Even if the web application isn't fully compromised, an exploited vulnerability could still lead to the web application being used to launch attacks against users of the site.

Minimal	Basic information disclosure (e.g. web server type, programming language) might enable intruders to discover other vulnerabilities, but lack of this information does not make the vulnerability harder to find.
Medium	Intruders may be able to collect sensitive information about the application platform, such as the precise version of software used. With this information, intruders can easily exploit known vulnerabilities specific to software versions. Other types of sensitive information might disclose a few lines of source code or hidden directories.
Serious	Vulnerabilities at this level typically disclose security-related information that could result in misuse or an exploit. Examples include source code disclosure or transmitting authentication credentials over non-encrypted channels.
Critical	Intruders can exploit the vulnerability to gain highly sensitive content or affect other users of the web application. Examples include certain types of cross-site scripting and SQL injection attacks.
Urgent	Intruders can exploit the vulnerability to compromise the web application's data store, obtain information from other users' accounts, or obtain command execution on a host in the web application's architecture.

Potential Vulnerabilities

Potential Vulnerabilities indicate that the scanner observed a weakness or error that is commonly used to attack a web application, and the scanner was unable to confirm if the weakness or error could be exploited. Where possible, the QID's description and results section include information and hints for following-up with manual analysis. For example, the exploitability of a QID may be influenced by characteristics that the scanner cannot confirm, such as the web application's network architecture, or the test to confirm exploitability requires more intrusive testing than the scanner is designed to conduct.

Minimal	Presence of this vulnerability is indicative of basic information disclosure (e.g. web server type, programming language) and might enable intruders to discover other vulnerabilities. For example in this scenario, information such as web server type, programming language, passwords or file path references can be disclosed.
Medium	Presence of this vulnerability is indicative of basic information disclosure (e.g. web server type, programming language) and might enable intruders to discover other vulnerabilities. For example version of software or session data can be disclosed, which could be used to exploit.
Serious	Presence of this vulnerability might give access to security-related information to intruders who are bound to misuse or exploit. Examples of what could happen if this vulnerability was exploited include bringing down the server or causing hindrance to the regular service.
Critical	Presence of this vulnerability might give intruders the ability to gain highly sensitive content or affect other users of the web application.
Urgent	Presence of this vulnerability might enable intruders to compromise the web application's data store, obtain information from other users' accounts, or obtain command execution on a host in the web

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.

application's architecture. For example in this scenario, the web application users can potentially be targeted if the application is exploited.

Sensitive Content

Sensitive content may be detected based on known patterns (credit card numbers, social security numbers) or custom patterns (strings, regular expressions), depending on the option profile used. Intruders may gain access to sensitive content that could result in misuse or other exploits.

Minimal	Sensitive content was found in the web server response. During our scan of the site form(s) were found with field(s) for credit card number or social security number. This information disclosure could result in a confidentiality breach and could be a target for intruders. For this reason we recommend caution.
Medium	Sensitive content was found in the web server response. Specifically our service found a certain sensitive content pattern (defined in the option profile). This information disclosure could result in a confidentiality breach and could be a target for intruders. For this reason we recommend caution.
Serious	Sensitive content was found in the web server response - a valid social security number or credit card information. This infomation disclosure could result in a confidentiality breach, and it gives intruders access to valid sensitive content that could be misused.

Information Gathered

Information Gathered issues (QIDs) include visible information about the web application's platform, code, or architecture. It may also include information about users of the web application.

Minimal	Intruders may be able to retrieve sensitive information related to the web application platform.
Medium	Intruders may be able to retrieve sensitive information related to internal functionality or business logic of the web application.
Serious	Intruders may be able to detect highly sensitive data, such as personally identifiable information (PII) about other users of the web application.

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.